

Day 06: Cloud Computing and Governance

Cloud Computing & Big Data Analytics | Digital Science — Graduate Level | Cyber.SoHo

Today's Learning Objectives

- Explain the three service models and four deployment models of the cloud
- Identify shared-responsibility boundaries between provider and tenant
- Describe what cloud governance is and why it matters
- Map governance controls to real data-science scenarios

Agenda Overview

Lesson 1: Cloud Computing

- NIST definition & 5 characteristics
- Service models: IaaS, PaaS, SaaS
- Deployment models
- Shared responsibility model
- Cloud economics: CapEx vs. OpEx

Lesson 2: Cloud Governance

- Governance definition & 6 domains
- Regulatory compliance frameworks
- IAM & least privilege
- Data governance & encryption
- Frameworks, tools, & checklists

Lesson 1 : Cloud Computing

Fundamentals of cloud infrastructure and service delivery

What Is Cloud Computing?

NIST (National Institute of Standards and Technology) Definition:

On-demand network access to a shared pool of configurable computing resources that can be rapidly provisioned and released with minimal management effort.

Analogy: Instead of building a power plant, you plug into the grid and pay per kilowatt-hour.

Reference: NIST SP 800-145

Five Essential Characteristics

#	Characteristic	Meaning
1	On-demand self-service	Provision resources without human intervention
2	Broad network access	Available from any device via standard protocols
3	Resource pooling	Multi-tenant: many customers share physical hardware
4	Rapid elasticity	Scale up/down in minutes, not months
5	Measured service	Pay only for what you consume

Service Models — The Pizza Analogy

Model	You Manage	Provider Manages	Analogy
IaaS (Infrastructure as a Service)	OS, runtime, apps, data	Hardware, networking	Renting a bare kitchen
PaaS (Platform as a Service)	Apps, data	OS, runtime, middleware	Fully equipped kitchen
SaaS (Software as a Service)	Just your data	Everything	Ordering delivery

KEY TAKEAWAY: More control = more responsibility. Pick the highest abstraction that meets your requirements.

IaaS — Infrastructure as a Service

- **You rent raw compute, storage, and networking**
- You manage: Operating system, runtime, applications, data
- Provider manages: Physical servers, networking, virtualisation

- **Key Providers:**
 - AWS EC2 (Elastic Compute Cloud)
 - Azure Virtual Machines
 - Google Compute Engine (GCE)

- **Best for: Custom environments, full control, GPU-heavy ML workloads**

PaaS — Platform as a Service

- **You deploy code; the platform handles the rest**
- You manage: Application code, data
- Provider manages: OS, runtime, middleware, scaling
- **Key Providers:**
 - Google App Engine (GAE), Heroku, Azure App Service
 - Google Vertex AI (for managed ML training)
- **Best for: Rapid prototyping, managed ML training, web applications**

SaaS — Software as a Service

- **Ready-to-use applications over the internet**
- You manage: Your content and configuration only
- Provider manages: Everything else

- **Key Providers:**
 - Google Workspace, Salesforce, Dropbox

- **Best for: End-user tools, no-code analytics, team collaboration**

Choosing the Right Service Model

Factor	IaaS	PaaS	SaaS
Control	Highest	Medium	Lowest
Setup time	Hours	Minutes	Minutes
Cost model	Per-hour compute	Per-job	Subscription
Skill required	High (DevOps)	Medium	Low
Flexibility	Maximum	Moderate	Limited

The Four Deployment Models

Model	Description	Example
Public	Provider-owned, open to all	AWS, Azure, GCP
Private	Operated for one organisation	Hospital's OpenStack cluster
Hybrid	Public + Private combined	Bank: on-prem daily + cloud burst
Community	Shared by orgs with common needs	AWS GovCloud (US gov)

Hybrid Cloud — Why It Matters

- **When you cannot go all-public:**
 - Regulation: HIPAA / GDPR may require data residency
 - Sensitivity: PII stays on-prem; anonymised data goes to cloud
 - Performance: Low-latency inference on-prem, heavy training in cloud
- **Common Pattern:**
 - Private cloud (sensitive data) $\leftrightarrow$ Public cloud (compute power)
 - Data is anonymised before crossing the boundary

The Shared Responsibility Model

Layer	IaaS	PaaS	SaaS
Physical security	Provider	Provider	Provider
Network controls	CUSTOMER	Provider	Provider
OS patching	CUSTOMER	Provider	Provider
Application security	CUSTOMER	CUSTOMER	Provider
Data & access control	CUSTOMER	CUSTOMER	CUSTOMER

KEY TAKEAWAY: You ALWAYS own responsibility for your data and who accesses it — regardless of service model.

Real-World Consequence: Misconfigured S3

- Team uploads sensitive data to AWS S3 (Simple Storage Service) bucket
- Junior engineer accidentally sets bucket to "public"
- Data exposed to the entire internet within hours
- AWS infrastructure was never breached — the configuration was the customer's job
- **Root cause: Failure to implement the customer side of the shared responsibility model**
- Prevention: Weekly automated S3 permission audits + bucket policies + AWS Config rules

Cloud Economics — CapEx vs. OpEx

Aspect	CapEx (Capital Expenditure)	OpEx (Operational Expenditure)
Upfront cost	High (buy servers)	Near zero
Ongoing cost	Low (maintenance)	Pay-per-use
Scaling speed	Weeks to months	Minutes
Over-provision risk	High	Low
Accounting	Depreciated asset	Monthly expense

KEY TAKEAWAY: Cloud wins for variable workloads (<70% utilisation). On-prem wins for sustained, maxed-out hardware (>70%).

Lesson 1 — Key Takeaways

- 1. Five characteristics define cloud computing (NIST SP 800-145)
 - 2. Three service models (IaaS → PaaS → SaaS) trade control for convenience
 - 3. Four deployment models serve different regulatory and security needs
 - 4. Shared responsibility: provider secures infra; you secure config & data
 - 5. CapEx vs. OpEx — cloud shifts spending from capital to operational
-

Lesson 2 : Cloud Governance

Policies, controls, and frameworks for responsible cloud management

What Is Cloud Governance?

The set of policies, processes, and controls that manage a cloud environment to be secure, compliant, cost-effective, and strategy-aligned.

Analogy:

Cloud computing = **sports car**

Cloud governance = **traffic laws + insurance + driving instructor**

The Six Governance Domains

#	Domain	Core Question
1	Risk Management	What could go wrong?
2	Compliance	Are we meeting legal requirements?
3	Cost Management	Are we spending wisely?
4	Identity & Access	Who can do what?
5	Data Governance	How to classify, protect, lifecycle data?
6	Operations Governance	Are resources provisioned consistently?

Source: Cloud Security Alliance (CSA)

Cost Governance — The \$12,400 Weekend

- Intern launches 8× NVIDIA A100 GPUs for hyperparameter sweep
- Forgets to shut down over the weekend
- **Monday morning: \$12,400 in charges for 60 hours of idle GPU time**
- **What should have been in place:**
 - IAM policy — limit intern to 2 GPUs maximum
 - Budget alert at \$500 — email + SMS to professor
 - Auto-shutdown policy — stop instances after 2h idle

KEY TAKEAWAY: Cost governance is not bureaucracy — it is survival.

Regulatory Compliance Frameworks (1/2)

Framework	Full Name	Jurisdiction	Key Requirement
GDPR	General Data Protection Regulation	EU / EEA	Right to erasure, consent
HIPAA	Health Insurance Portability & Accountability Act	United States	De-identify PHI
SOC 2	System & Organisation Controls 2	Global	Third-party security audit

Regulatory Compliance Frameworks (2/2)

Framework	Full Name	Jurisdiction	Key Requirement
PCI DSS	Payment Card Industry Data Security Standard	Global	Encrypt cardholder data
PIPEDA	Personal Information Protection & Electronic Documents Act	Canada	Consent-based collection

KEY TAKEAWAY: Know which frameworks apply to your data BEFORE you touch it. Ignorance is never a defence.

GDPR — Right to Erasure in Practice

- **When a user says: "Delete all my data" (GDPR Article 17)**
- Step 1: DISCOVER — Search every data store (S3, RDS, caches, backups)
- Step 2: DELETE / ANONYMISE — Remove records from ALL stores
- Step 3: LOG — Document in an immutable audit trail
- Step 4: CONFIRM — Notify the user within 30 days

KEY TAKEAWAY: Deletion is a governance process, not just a SQL query.

IAM — Identity and Access Management

Question	IAM Function	Examples
Who are you?	Authentication	Passwords, MFA, SSO
What can you do?	Authorisation	Roles, policies, permissions
What did you do?	Accountability	Audit trails, CloudTrail logs

KEY TAKEAWAY: The Golden Rule — Least Privilege: give every user the minimum permissions they need, nothing more.

IAM Role Design for Data-Science Teams

Person	Role	Permitted	Denied
Professor	Project Owner	All + billing	None
Senior PhD	ML Engineer	Training, data read	IAM, billing
Junior MSc	Data Analyst	Data read, queries	GPU, deletes
Intern	Viewer	Read dashboards	Write anything
CI/CD Pipeline	Service Account	Deploy staging	Production

KEY TAKEAWAY: An explicit Deny always overrides an Allow in AWS IAM policy evaluation.

Data Governance — Classification Tiers

Tier	Label	Example	Controls
1	Public	Marketing copy	No encryption needed
2	Internal	OKR documents	Encrypted at rest
3	Confidential	Customer PII	Encrypted rest + transit, logged
4	Restricted	Health / payment data	All above + dedicated keys

KEY TAKEAWAY: Classify first, then apply controls. Never store Tier 4 data with Tier 1 protections.

Data Lifecycle Management

Stage	Timing	Storage Class	Cost/GB/Month
Hot	Day 0–89	S3 Standard	\$0.023
Cold	Day 90–364	S3 Glacier	\$0.004
Deleted	Day 365+	Gone	\$0.000

- **Why automate lifecycle rules?**
 - Cost: Glacier is ~83% cheaper than Standard
 - Compliance: GDPR mandates no excess retention
 - Risk: Less data stored = smaller breach surface

Encryption — At Rest and In Transit

Boundary	Meaning	Technology
At rest	Data on disk	AES-256, SSE-KMS
In transit	Data on the network	TLS 1.3 / HTTPS

- **Key Management Options:**
 - Provider-managed keys — easy, less control
 - Customer-managed keys (CMK) — you control rotation & access
 - HSM (Hardware Security Module) — highest security, tamper-resistant

Governance Frameworks (1/2)

Framework	Issuer	Focus
COBIT	ISACA	IT governance and management
CSA CCM (Cloud Controls Matrix)	Cloud Security Alliance	Cloud-specific security controls
ISO/IEC 27001	ISO	Information security management

Governance Frameworks (2/2)

Framework	Issuer	Focus
NIST CSF	NIST	Identify, Protect, Detect, Respond, Recover
Well-Architected Frameworks	AWS / Azure / GCP	Provider-specific best practices

- **Cloud-Native Governance Tools:**
 - AWS Config — evaluates resource configurations against rules
 - Azure Policy — enforces organisational standards
 - Terraform + OPA (Open Policy Agent) — infrastructure + policy as code

Governance Automation

Approach	Speed	Coverage	Human Error
Manual audit	Slow (days)	Partial	High
Scheduled script	Medium (hours)	Good	Medium
Continuous monitoring	Real-time	Full	Low

- **Example: "No Unencrypted Storage" rule via AWS Config**
 - Scans every S3 bucket continuously
 - Non-compliant buckets flagged automatically
 - Governance team remediates within SLA

Pre-Deployment Governance Checklist

#	Question	Domain
1	Deployment model per regulation?	Compliance
2	Data classified by sensitivity?	Data Governance
3	Encryption at rest + in transit?	Data Governance
4	Least-privilege IAM for all?	Identity & Access
5	Budget alert configured?	Cost Management
6	Lifecycle rules on storage?	Data Governance
7	Config monitoring active?	Operations
8	Incident-response plan?	Risk Management
9	Audit trail enabled?	Compliance
10	Documentation complete?	Operations

KEY TAKEAWAY: Score 10/10 before deploying. Any gap = no-go.

Lesson 2 — Key Takeaways

- 1. Six domains cover risk, compliance, cost, IAM, data, and operations
- 2. Cost governance prevents surprise bills — budget alerts are mandatory
- 3. Compliance (GDPR, HIPAA, PIPEDA) is not optional
- 4. IAM + least privilege is the #1 security control
- 5. Data governance = classify → encrypt → lifecycle → audit
- 6. Automate governance with AWS Config, Azure Policy, OPA
- 7. Checklist every deployment — governance is a gate, not an afterthought

Full Lecture Summary

Lesson 1: Cloud Computing

- NIST definition, 5 characteristics
- IaaS → PaaS → SaaS (control vs. convenience)
- Public / Private / Hybrid / Community deployment
- Shared responsibility = you own your data security
- CapEx (buy) vs. OpEx (rent)

Lesson 2: Cloud Governance

- Six domains: risk, compliance, cost, IAM, data, ops
- Frameworks: GDPR, HIPAA, SOC 2, PCI DSS, PIPEDA
- IAM with least privilege
- Classify → Encrypt → Lifecycle → Audit
- COBIT, CSA CCM, ISO 27001, NIST CSF
- Automate with cloud-native tools

Essential Hyperlinks

Resource	URL
NIST SP 800-145	csrc.nist.gov/publications/detail/sp/800-145/final
AWS Shared Responsibility	aws.amazon.com/compliance/shared-responsibility-model/
GDPR Official	gdpr.eu
HIPAA (US HHS)	hhs.gov/hipaa
Cloud Security Alliance	cloudsecurityalliance.org
NIST Cybersecurity Framework	nist.gov/cyberframework
AWS Config	aws.amazon.com/config/
Open Policy Agent	openpolicyagent.org
PIPEDA (Canada)	priv.gc.ca
VirusTotal (link checker)	virustotal.com/gui/home/url

Disclaimer

Intellectual Property: © 2026 Cyber.SoHo — All rights reserved

Non-Affiliation: Not affiliated with or endorsed by AWS, Azure, GCP, NIST, ISO, ISACA, CSA, or any referenced entity

External Links: Verify all URLs with VirusTotal ([virustotal.com](https://www.virustotal.com)) before clicking

Liability: Material provided "as is" for educational purposes only

Ethics: Prepared with commitment to academic integrity